SAVEETHA

INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

Max Marks: **50 Marks**

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes

On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting.

   (CO1) (BL3)

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student

under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical-hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive. **(CO1) (BL3) (5 Marks)**

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS. **(CO2) (BL4)**

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures. **(CO2) (BL3)**

ITA1439 - Ethical Hacking

CIA-1

Sayed Fazal

19231129

1A) Hacker:

A hacker is a person who uses technical knowledge and computer skills to access, analyze, modify or test computer systems, networks and applications.

White Hat Hackers:

An ethical hacker who works with proper authorization to identify and fix security vulnerabilities.

Ex: They are legally hired by the bank to identify security weakness in the internet-banking portal with permission.

Grey Hat Hacker:

A person who discovers security vulnerabilities without permission but may report them to the organization instead of exploiting them maliciously.

White Hat HACKER:

An ethical hacker who works with proper authorization to identify and fix security vulnerabilities.

Ethical principles that Security Testers follow: 2A)

1. Written Authorization

Testers must obtain official written permission from the bank before starting the security testing.

2. Agreed Scope

Testing must be performed only on the systems and applications approved by the bank.

3. Confidentiality

Testers may come across sensitive information such as customer names, passwords, account details and transaction records.

4. Avoiding Harm

Testers should perform security testing carefully without affecting the bank's normal operations.

5. Honest Reporting

Testers must provide accurate reports about the vulnerabilities they discover.

6. Responsible Disclosure

If testers discover a security vulnerability they should report it privately to the bank.

2A) SQL Injection:

SQL Injection is a web application security vulnerabilities in which an attacker inserts malicious SQL commands into input fields to access or manipulate a database.

Legal position under ACT 2000:

A. Section 43 - Unauthorized access and Data theft:

Section 43 of the IT Act deals with unauthorized access and damage to Computer systems.

B. Section 66 - Computer-Related offences:

Section 66 applies when a person commits an act described under Section 43 dishonestly or fraudulently.

C. Section 72A - Disclosure of Information in Breach of Lawful contract.

Section 72A deals with the disclosure of personal information obtained while providing services under a lawful Contract, without the person's consent and with the intention of causing wrongful loss or wrongful gain.

D. Section 72 - Breach of Confidentiality and Privacy:

Section 72 deals with unauthorized disclosure of inform by a person who obtained access to electronic records through powers granted under the IT act.

Full disclosure:

The researcher immediately publishes the vulnerability details publicly.

Ex: The student posts the SQL injection vulnerability and screenshots of student records on social media.

Coordinate disclosure:

The researcher privately informs the affected organization, the organization gets time to investigate and fix the it.

Ex: The student privately reports the SQL Injection flaw to the university's IT security team and waits for it to be fixed before publishing a general security advisory.

3A) a) Ethical Hacking:

Ethical hacking is the process of identifying security weakness in Computer systems, networks and applications with proper authorization from the organization

Phases of Ethical Hacking :-

1) Reconnaissance:

Gather information about the student portal, domain names, IP addresses and technologies used.

2) Scanning and Enumeration:

Scan authorized systems to identify open ports and running services.

3) Gaining Access:

Attempt controlled exploitation of identified vulnerability

4) Maintaining Access:

Evaluate whether an attacker could retain access after initially compromising a system.

5) Reporting:

Prepare a report containing identified vulnerabilities.

b) Footprinting :-

Footprinting is the fist step in ethical hacking it is the process of collecting information about an organization, its domain, network and online presence to identify potential security weaknesses.

Passive Footprinting :-

It is a process of collecting information about a target without directly interacting with its systems.

Ex: 1) Searching company information on google.

2) Checking WHOIS records.

Active Footprinting :-

Active footprinting involves directly interacting with the targets systems or network to collect information.

Ex:

1) Using nslookup or dig to query DN's records

2) Performing authorized port scanning.

3) Checking accessible services on company servers.

4A) DNS Zone Transfer & Security Risks:

DNS:

Domain Name System is used to translate domain names into IP addresses. It helps users access websites and online services using easy-to-remember domain names instead of IP addresses.

Types of DNS

1) AXFR (Full Zone Transfer):

. Transfers the complete DNS zone from the primary servers to the secondary server.

2) IXFR (Incremental Zone):

→ Transfers only the changes made since the previous transfer.

→ Reduces network traffic and saves time.

→ Used when only a few DNS records have been modified.

5A) Social Engineering:-

It is a cyberattack technique in which attackers manipulate people into revealing confidential information providing unauthorized access or unsafe actions.

Phishing:-

The attacker sends a fake email pretending to be from the organization's IT help desk and ask employees to verify their passwords through a malicious link

Vishing:-

The attacker calls the accounts section pretending to be an IT help desk employee and requests a one-time password (OTP).